

L2 - 6.2. AWS Security Logging

Task 1 - Introduction

Amazon Web Services (AWS) is one of the most used IaaS cloud providers, and many companies worldwide, including TryHackMe, heavily use its compute, storage, databases, networking, and ML services. This room explains the tools to monitor the AWS cloud environment for threats and provides best practices on auditing AWS activities in SIEM by the SOC.

Task 2 - What to Secure in AWS

Cloud Security Areas: What exactly we want to protect. To make it easier, imagine the simplest infrastructure built in AWS: a website hosted on a lab machine ([Amazon EC2\(opens in new tab\)](#)) that uses an AWS-managed SQL database ([Amazon RDS\(opens in new tab\)](#)) and a managed file storage ([Amazon S3\(opens in new tab\)](#)). To monitor it properly in a SOC, you need to cover at least three security areas:

1. **Control Plane:** Monitor the actions of those who access the AWS console and manage the infrastructure
2. **Workloads:** Monitor files and processes on the website's VM, same as you would do in on-premises
3. **Managed Services:** Monitor access to the RDS database and suspicious changes to the S3 file storage



Covering Big Networks:

Control Plane Chaos: Some IT teams manage AWS resources via a graphical interface while others use automation tools, such as [Terraform\(opens in new tab\)](#).

You must know how your IT operates to build strong detection rules and reliably differentiate good and bad.

Tenant refers to a customer or organization that shares access to a software application, database, or cloud infrastructure reserved exclusively for their use.

Terraform is an open-source **Infrastructure as Code (IaC)** tool created by HashiCorp. It allows you to define, provision, and manage cloud infrastructure (servers, databases, networks, security policies) using human-readable configuration code instead of manually clicking around in a cloud console.

Containerized Workload: Instead of regular lab machines, your IT can run its applications in managed containers ([Amazon Fargate](#)[\(opens in new tab\)](#)) or use other serverless technologies. In this case, you must learn how the new technology works in order to monitor it.

AWS Fargate is a serverless, pay-as-you-go compute engine that lets you run containers without having to manage the underlying servers, virtual machines (EC2 instances), or cluster infrastructure. Instead of managing operating systems, patch updates, or capacity planning, you simply package your application into a container, define its required resources (CPU and memory), and Fargate handles the provisioning, execution, and auto-scaling automatically.

Too Many Managed Services: AWS has [more than 200](#)[\(opens in new tab\)](#) managed services, many of which can be exploited in cyber attacks. The service selection by your company defines which logs SOC must ingest and which detection rules you must prepare.

Answer the questions below

| Which security area covers management actions within the AWS console?

Control Plane

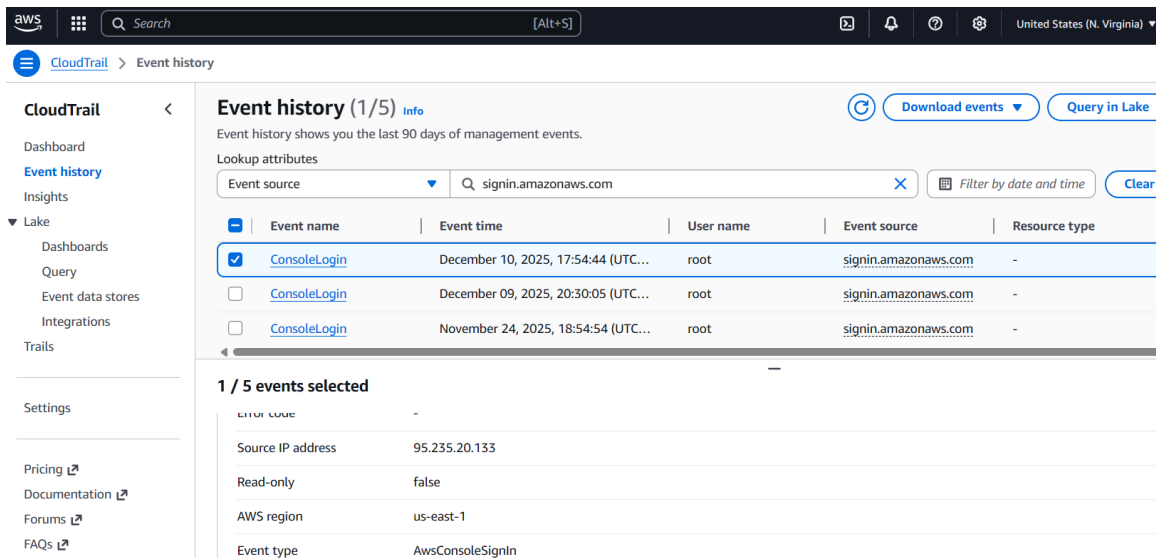
| Which of the mentioned AWS services provides lab machines in the cloud?

Amazon EC2

Task 3 - Covering AWS Control Plane

CloudTrail: CloudTrail is the first AWS service that any SOC analyst must know. This service records all control plane activities, including console logins, launch

of EC2 instances, access to S3 buckets, changes in user privileges and network settings, and more. Technically, CloudTrail is a service that logs all API calls you or your browser makes to the AWS servers. You can view CloudTrail logs in the **CloudTrail > Event history** menu:



The screenshot displays the AWS CloudTrail console's 'Event history' page. The left sidebar shows the navigation menu with 'Event history' selected. The main content area shows a table of events. The first event is selected, and its details are shown below the table.

Event name	Event time	User name	Event source	Resource type
☒ ConsoleLogin	December 10, 2025, 17:54:44 (UTC...)	root	signin.amazonaws.com	-
☐ ConsoleLogin	December 09, 2025, 20:30:05 (UTC...)	root	signin.amazonaws.com	-
☐ ConsoleLogin	November 24, 2025, 18:54:54 (UTC...)	root	signin.amazonaws.com	-

1 / 5 events selected

Field	Value
Source IP address	95.235.20.133
Read-only	false
AWS region	us-east-1
Event type	AwsConsoleSignIn

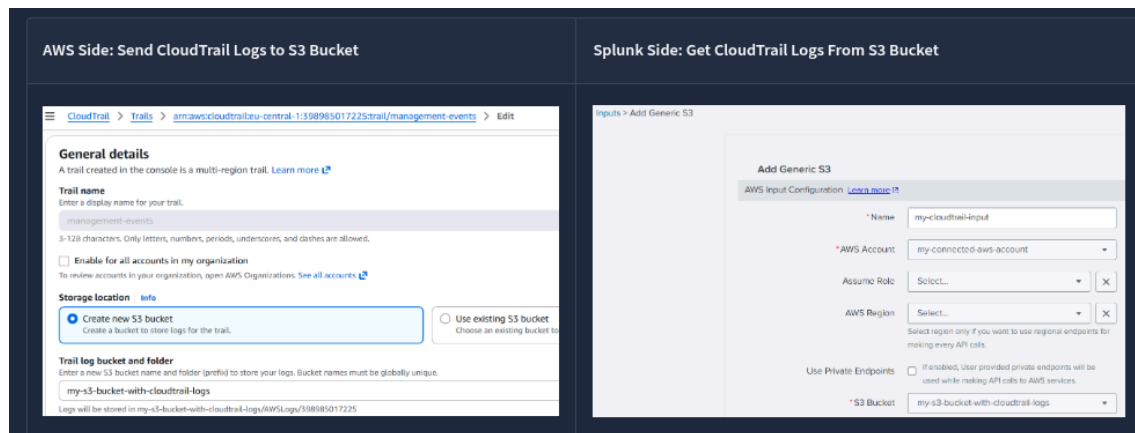
CloudTrail events are enabled by default and are available for free for the past 90 days(opens in new tab). However, if you want to keep logs longer (and you should), the common choice is to forward the logs to the S3 bucket, and then configure your SIEM to periodically pull the logs from that S3 bucket. The configuration process is a bit tedious, so it's better to refer to the Splunk documentation(opens in new tab) or other SIEM-specific guides.

S3 Buckets: Simple Storage Service (S3) is a service provided by Amazon Web Services (AWS) that allows you to store data in a scalable and reliable way. Data is stored on buckets, which act as a folder in the cloud where you can store files, applications, backup information or anything you need.

EC2: Elastic Compute Cloud (EC2) is a service provided by Amazon Web Services (AWS) that allows you to rent virtual PCs on the cloud. The machines can be used just as any regular PC, and their specs can be dimensioned according to your specific needs.

Log Format: The sample CloudTrail logs are ingested into the Splunk `aws` index, so you can inspect the log structure there. As a reminder, in AWS terminology, an account and a user are not the same thing: an account represents an entire cloud

tenant, while a user is an individual identity within that account. For example, you might have a `john.doe` user inside the `398985017225` AWS account.



Key CloudTrail Fields

- `eventSource`: AWS service that was requested. Similar to Windows event channels (e.g. Security)
- `eventName`: The name of the API call, such as **ConsoleLogin**, **RunInstances**, or **CreateBucket**
- `recipientAccountId`: The target AWS account of the API call. That's where the activity happened
- `sourceIPAddress`: Source of the API call. Useful to identify actions from an unusual location or known bad IPs
- `requestParameters`: Event-specific details. For **CreateBucket**, it will contain the name of the created S3 bucket
- `userIdentity.*`: Details about the actor behind the API call. ARN subfield is a globally unique user identifier
- `readOnly`: Whether the API call is a read (e.g. `GetObject`) or non-read (e.g. `PutObject`, `ConsoleLogin`) request

Answer the questions below

| From which IP did **jeff.harrison** user log in to AWS?

149.40.62.48

1 index=aws eventName=ConsoleLogin user_name="jeff.harrison" All time ▾

✓ 2 events (before 8/21/26 5:54:05.000 AM) No Event Sampling ▾ Job ▾ || ▢ → 📄 ⬇️ ⚡ Smart Mode

Events (2) Patterns Statistics Visualization

Timeline format ▾ — Zoom Out + Zoom to Selection × Deselect 1 minute per cc

Format ▾ Show: 20 Per Page ▾ View: List ▾

	i	Time	Event
	>	12/12/25 3:39:29.000 PM	<pre>{ [-] additionalEventData: { [+] } awsRegion: us-east-2 eventCategory: Management eventID: 6aae8f1e-1747-454e-b61e-51405b6f7ad1 eventName: ConsoleLogin eventSource: signin.amazonaws.com eventTime: 2025-12-12T15:39:29Z eventType: AwsConsoleSignIn eventVersion: 1.11 managementEvent: true readOnly: false recipientAccountId: 398985017225 requestParameters: null responseElements: { [+] } sourceIPAddress: 149.40.62.48 tlsDetails: { [+] } userAgent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36 userIdentity: { [+] } }</pre> Show as raw text host = ce-splunk source = cloudtrail.json sourcetype = aws:cloudtrail

< Hide Fields ≡ All Fields
 SELECTED FIELDS
 a host 1
 a source 1
 a sourcetype 1
 INTERESTING FIELDS
 a action 2
 a additionalEventData.LoginTo 2
 a additionalEventData.MFAUsed 1
 a additionalEventData.MobileVersion 1
 a app 1
 a authentication_method 1
 # aws_account_id 1
 a awsRegion 2
 a command 1
 # date_hour 1
 # date_mday 1
 # date_minute 2
 a date_month 1
 # date_second 2
 a date_wday 1
 # date_year 1
 # date_zone 1
 a desc 1
 a dest 2
 a dvc 1
 a errorCode 2

To which AWS account ID did **jeff.harrison** user log in?

398985017225

What S3 bucket did **jeff.harrison** create after the login?

prod-website-thm

index=aws eventName>CreateBucket user_name="jeff.harrison"

```

a object_attrs 1
a object_category 1
a object_id 1
a product 1
a punct 1
a readOnly 1
# recipientAccountId 1
a region 1
a requestID 1
a requestParameters.bucketName 1
a requestParameters.CreateBucketCo
nfiguration.LocationConstraint 1
a requestParameters.CreateBucketCo
nfiguration.xmlns 1
a requestParameters.Host 1
a responseElements 1
a signature 1
a sourceIPAddress 1

```

requestParameters.bucketName ×

1 Value, 100% of events Selected

Reports
[Top values](#) [Top values by time](#) [Rare values](#)
[Events with this field](#)

Values	Count	%
prod-website-thm	1	100%

Task 4 - CloudTrail and GuardDuty

CloudTrail Usage: Once CloudTrail is in your SIEM, you can start using it for control plane monitoring. This is essential because your IT team may accidentally expose internal resources, grant excessive permissions, or fall victim to a cyber attack. CloudTrail gives you the visibility needed to detect all these incidents by recording every API call. For example, imagine SSH access to your Linux VM suddenly becomes public, and you need to know who changed the firewall rules. Simply search CloudTrail for `ModifySecurityGroupRules` events and review the matching record.

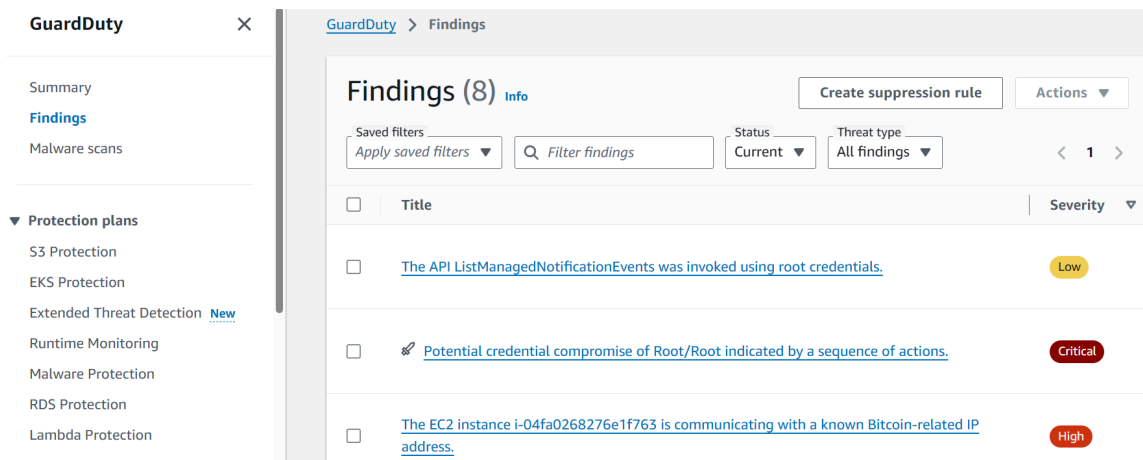
Control Plane Threats: To get started, focus on the key areas below:

- Start from the write events (`readOnly=false`), as they often indicate a high-risk change
- **IAM:** Look for changes in user privileges, IAM access keys, and unusual AWS logins
- **EC2:** Alert on insecure changes to the EC2 security groups, such as exposed RDP
- **S3:** Alert whenever S3 buckets are made public, as they are often exposed by mistake

Meet GuardDuty: GuardDuty is an AWS service that automatically analyzes control plane, network, DNS, and endpoint activities within AWS and generates alerts on suspicious behavior in real time. It is a paid service, but you can have a

30-day trial, simulate an attack, and see the alerts in **GuardDuty > Findings** tab. GuardDuty is a perfect choice for companies without a SOC, because it is ready to use out of the box and has many built-in detection rules (finding types) covering the most common AWS threats, such as:

GuardDuty Finding Type	Description
Exfiltration:IAMUser/AnomalousBehavior(opens in new tab)	The user performed suspicious control plane actions, often seen during data exfiltration
Policy:S3/BucketAnonymousAccessGranted(opens in new tab)	The S3 bucket was configured to allow public, anonymous access from the Internet
UnauthorizedAccess:EC2/RDPBruteForce(opens in new tab)	The EC2 instance is exposed to the Internet and is a target of the RDP brute force
Impact:EC2/BitcoinDomainRequest.Reputation(opens in new tab)	The EC2 instance queried a known domain related to cryptocurrency mining



GuardDuty and SOC: GuardDuty is likely the best monitoring service for companies without a strong security team, as it is very easy to use, can detect a large number of common threats, and does not require much knowledge to be effectively used by IT. However, any mature SOC team would still need to collect and monitor raw logs, such as CloudTrail, because:

- GuardDuty alerts often lack sufficient context to fully scope and document the attack
- GuardDuty detection rules do not adapt to your company-specific policies and risks
- GuardDuty is effective against common threats, but is unlikely to detect advanced attacks
- Finally, GuardDuty can't reliably detect when AWS logging is tampered with or disabled

Practice:

- CloudTrail logs: `index=aws sourcetype=aws:cloudtrail`
- GuardDuty alerts: `index=aws sourcetype=aws:cloudwatch:guardduty`

Answer the questions below

Find the "AnomalousBehavior" GuardDuty alert in the logs. From which VPN did the suspicious activity originate?

ProtonVPN

`index=aws sourcetype=aws:cloudwatch:guardduty`

```

motelpDetails.GeoLocation.Lon 1
a Service.Action.AwsApiCallAction.Re
motelpDetails.IpAddressV4 1
# Service.Action.AwsApiCallAction.Re
motelpDetails.Organization.Asn 1
a Service.Action.AwsApiCallAction.Re
motelpDetails.Organization.AsnOrg 1
a Service.Action.AwsApiCallAction.Re
motelpDetails.Organization.Org 1
a Service.Action.AwsApiCallAction.Ser
viceName 1
a Service.Action.DnsRequestAction.Blo
cked 1
a Service.Action.DnsRequestAction.Do
main 1
a Service.Action.DnsRequestAction.Do
mainWithSuffix 1
a Service.Action.DnsRequestAction.Pr

```

Service.Action.AwsApiCallAction.RemoteIpDetails.Organization...
X

1 Value, 33.333% of events

Selected Yes No

Reports

Top values
Top values by time
Rare values

Events with this field

Values	Count	%
ProtonVPN	1	100%

Analyze two other alerts from the **i-04fa0268276e1f763** EC2 instance. What is the path to the detected malware, and which domain did it query?

/home/ubuntu/xmrig-6.24.0/xmrig, [donate.v2.xmrig.com](https://xmrig.com)

emCount 1

a Service.EbsVolumeScanDetails.ScanDetections.ThreatDetectedByName.Shortened 1

a Service.EbsVolumeScanDetails.ScanDetections.ThreatDetectedByName.ThreatNames().FilePaths().FileName 1

a Service.EbsVolumeScanDetails.ScanDetections.ThreatDetectedByName.ThreatNames().FilePaths().FilePath 2

a Service.EbsVolumeScanDetails.ScanDetections.ThreatDetectedByName.ThreatNames().FilePaths().Hash 1

a Service.EbsVolumeScanDetails.ScanDetections.ThreatDetectedByName.ThreatNames().FilePaths().VolumeArn 1

a Service.EbsVolumeScanDetails.Scan

Service.EbsVolumeScanDetails.ScanDetections.ThreatDetected...

2 Values, 33.333% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
/home/ubuntu/xmrig-6.24.0-noble-x64.tar.gz=>xmrig-6.24.0/xmrig	1	100%
/home/ubuntu/xmrig-6.24.0/xmrig	1	100%

a Service.Action.AwsApiCallAction.RemoteIpDetails.Organization.AsnOrg 1

a Service.Action.AwsApiCallAction.RemoteIpDetails.Organization.Org 1

a Service.Action.AwsApiCallAction.ServiceName 1

a Service.Action.DnsRequestAction.Blocked 1

a Service.Action.DnsRequestAction.Domain 1

a Service.Action.DnsRequestAction.DomainWithSuffix 1

a Service.Action.DnsRequestAction.Protocol 1

Service.Action.DnsRequestAction.VpcOwnerId 1

a Service.AdditionalInfo.Type 1

a Service.AdditionalInfo.Value 3

Service.Action.DnsRequestAction.Domain

1 Value, 33.333% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
donate.v2.xmrig.com	1	100%

Continue to the CloudTrail logs to get more instance context. Who created the infected EC2 instance? Provide the full ARN field.

arn:aws:iam::398985017225:root

run the query below, select userIdentity.arn section

Select Fields

Select All Within Filter Deselect All Coverage: 1% or more ▾

i	✓ ▾	Field ▾	# of Values ▾
>	☐	resources[].ARN	2
▼	☐	userIdentity.arn Reports Top values Events with this field Top values by time Rare values	1
		arn:aws:iam::398985017225:root 2 100%	
>	☐	user_arn	1

Which two risky ports did that user expose for the EC2 instance?

22, 3389

Select Fields

Select All Within Filter Deselect All Coverage: 1% or more ▾

i	✓ ▾	Field ▾	# of Values ▾	Event Cover
>	☐	requestParameters.ModifySecurityGroupRulesRequest.SecurityGroupRule.SecurityGroupRule.FromPort	2	
▼	☐	requestParameters.ModifySecurityGroupRulesRequest.SecurityGroupRule.SecurityGroupRule.ToPort Reports Top values Average over time Events with this field Top values by time Maximum value over time Rare values Minimum value time	2	
		22 1 50%		
		3389 1 50%		

Task 5 - Covering Managed Services

Covering Managed Services: CloudTrail is ideal for capturing control plane operations, but it doesn't provide visibility into service-specific actions. For

example, it cannot see queries made to an Amazon RDS database, network traffic flowing through your [VPCs\(opens in new tab\)](#), web requests served through Amazon CloudFront, and many other operations. To cover this blind spot, AWS provides detailed logging capabilities for each major service separately.

VPC Flow Logs is a cloud security and networking feature that captures and records details about the IP traffic moving to and from network interfaces in your Virtual Private Cloud (VPC).

CloudFront Logs: CloudFront is a CDN service heavily used by AWS customers to optimize and secure web applications. Its competitors: Cloudflare, Fastly, and Akamai. The importance of this service is that it usually routes all web traffic and thus can capture SQL injections, CVE exploits, web shell uploads, brute force, and DDoS attacks. The log format is very similar to IIS access logs and follows the W3C standard, where `c/cs` prefix refers to client fields, and `s/sc` denotes server-side fields:

A **Content Delivery Network (CDN)** is a geographically distributed network of proxy servers and data centers. Its primary job is to deliver web content (like images, video streams, JavaScript, and HTML pages) to users as quickly, securely, and reliably as possible by serving the data from a location physically close to the user.

IIS Access Logs record all incoming HTTP and HTTPS requests handled by Microsoft's Internet Information Services (IIS) web server.

A **W3C Standard** refers to an open specification or guideline established by the **World Wide Web Consortium (W3C)** to ensure long-term growth, interoperability, and accessibility across the Web.

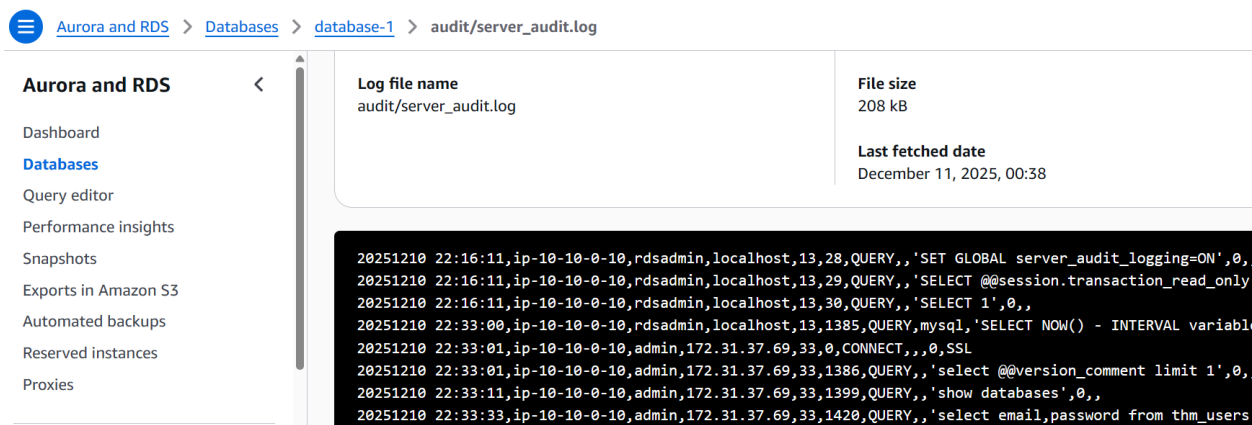
VPC Flow Logs: In the on-premises world, you would collect network logs from your firewall devices. But how would you monitor traffic in the cloud? AWS offers several services for auditing network traffic, with Amazon VPC Flow being the most notable one. This service records network flows to, from, and between your cloud workloads, giving you visibility into how systems communicate across your subnets. You will find many fields there, most importantly:

- `srcaddr` and `dstaddr` : Source and destination IP address of the flow
- `srcport` and `dstport` : Source and destination network port of the flow

- **protocol** : IANA protocol number of the traffic (TCP is 6, UDP is 17, ICMP is 1)
- **action** : Whether the traffic was allowed by AWS security groups and ACLs
- **account-id** , **vpc-id** , **interface-id** : Additional context about the traffic source

S3 Data Events: Remember that CloudTrail audits control plane activities and doesn't log operations inside managed services. However, CloudTrail can be extended to record Data events ([CloudTrail > Your Trail > Data Events](#)) for some of the services, including S3. With Data events, you will see operations on individual S3 objects, such as file access (GetObject) or upload to the bucket (PutObject).

Other Events: CloudWatch is yet another AWS service widely used for centralized logging and monitoring. Depending on your environment, CloudWatch may contain dozens of service logs, from databases and VMs to Kubernetes and AI. At some point, you may be required to connect CloudWatch with your SIEM to monitor services like RDS:



The screenshot shows the AWS Aurora and RDS console. The breadcrumb navigation is: Aurora and RDS > Databases > database-1 > audit/server_audit.log. On the left, there's a sidebar with navigation links: Dashboard, Databases (selected), Query editor, Performance insights, Snapshots, Exports in Amazon S3, Automated backups, Reserved instances, and Proxies. The main content area shows details for the log file 'audit/server_audit.log', including its size (208 kB) and the last fetched date (December 11, 2025, 00:38). Below this, a log viewer displays a series of database events, including queries and connections, with timestamps and IP addresses.

Amazon RDS (Relational Database Service) is a fully managed cloud database service by Amazon Web Services (AWS) that simplifies setting up, operating, and scaling relational databases. Instead of manually installing database software, configuring hardware, and handling maintenance on a raw virtual server (EC2), RDS automates routine database tasks.

Practice:

- CloudFront logs: `index=aws source="cloudfront.log"`
- S3 data events: `index=aws source="s3.json"`

Answer the questions below

Start with the CloudFront access logs. Which IP address logged in to the admin portal?

168.84.119.124

Run the query `index=aws source="cloudfront.log"`

Filter `/admin/login` in `cs_url_stem`

cs_url_stem >100

Reports

Top values
Top values by time
Rare values

Events with this field

/search	105	21.042%	
/home/	98	19.639%	
/	79	15.832%	
/login	32	6.413%	
/admin/login	2	0.401%	
/admin/dashboard	1	0.2%	
/post/05oeq8a6dl/like	1	0.2%	
/post/0842kva012/like	1	0.2%	
/post/0mj358t86	1	0.2%	
/post/0t7b14q24	1	0.2%	

< Hide Fields All Fields

SELECTED FIELDS

- a host 1
- a source 1
- a sourcetype 1

INTERESTING FIELDS

- a c_ip 1
- # c_port 2
- # cs_bytes 2
- a cs_cookie 1
- a cs_host 1
- a cs_method 1
- a cs_protocol 1
- a cs_protocol_version 1
- a cs_referer 1
- a cs_uri_query 1

i	Time	Event
>	12/12/25	2025-12-12 15:40:33 SF053-C1 1298

c_ip

1 Value, 100% of events Selected Yes

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
168.84.119.124	2	100%

host = ce-splunk source = cloudfront.log sourcetype =

Find an answer in the same CloudFront logs. How many IPs searched for the "tryhackme" keyword?

14

▼ ☐ cs_url_query

Reports

Top values Events with this field
Top values by time
Rare values

-	394	78.958%	
q=tryhackme	14	2.806%	
q=oauth-logs	13	2.605%	
q=forensics	12	2.405%	
q=ransomware-detection	11	2.204%	
q=kerberos-attack	10	2.004%	
q=incident-response	8	1.603%	
q=soc-playbooks	8	1.603%	
q=email-security	7	1.403%	
q=mssp-tools	7	1.403%	

Now, move on to the S3 Data events. Which interesting S3 file has been accessed?

backup.tar.gz

index=aws source="s3.json" eventName=GetObject

a punct 1
a readOnly 1
recipientAccountId 1
a region 1
a requestID 2
a requestParameters.bucketName 1
a requestParameters.Host 1
a requestParameters.key 2
resources[].accountId 1
a resources[].ARN 3
a resources[].type 2
a responseElements 1
a sharedEventID 2
a signature 1
a sourceIPAddress 1
a s3url server 1

requestParameters.key

2 Values, 100% of events

Selected

Reports

Top values Top values by time Rare values

Events with this field

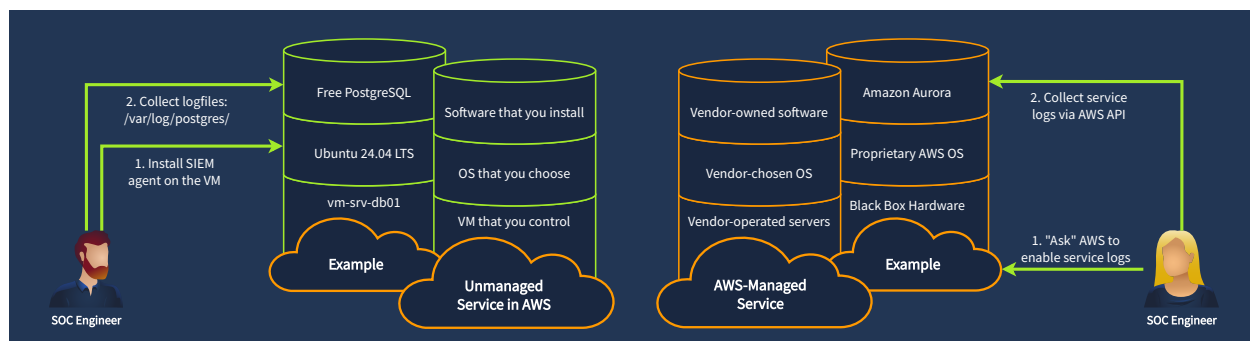
Values	Count	%	
admin/backup.tar.gz	1	50%	
index.html	1	50%	

userAgent: [aws-cli/2.31.39 md/awscli#0.28.4 ua/2.1 os/windows#11 m

Task 6 - Logging of AWS Workloads

Workloads and Services: The previous task focused on logging fully AWS-managed services - solutions like Amazon S3 that the vendor builds, maintains, and patches on your behalf. However, some companies choose not to rely on managed services due to cost concerns, government regulations, or other constraints. Instead, they run the necessary software on EC2 instances or integrate the cloud with their on-premises data centers. For example, they can:

- Install PostgreSQL on a lab machine (EC2) instead of using managed Amazon Aurora
- Keep confidential document scans in an on-premises data center rather than in S3
- Deploy and configure Nginx web proxies instead of relying on AWS load balancers
- Run niche software on EC2 that is not available through any AWS-managed service



Containerized Workloads: Small cloud-adopting companies typically run between 5 and 20 EC2 instances, along with a few managed services such as S3 for storing uploaded images. Monitoring is straightforward in such environments. However, at some point, the IT team may decide to migrate workloads into containers (for example, using Amazon ECS) or adopt serverless technologies, such as AWS Lambda. We will cover these in detail in another room, but please keep the following in mind for reference:

Important Information	Possible Solution
Auditd and most EDR solutions don't work effectively in containers.	Use cloud-native tools such as Falco , or CWPP solutions like Wiz (opens in new tab).
All traditional monitoring agents can't operate in serverless workloads.	Use CWPP or refer to AWS security guidelines for that specific service.
You can't protect cloud environments without understanding containers.	Master your Linux knowledge and learn about containers and Kubernetes!

Answer the questions below

How would you call a service that is built and maintained by the cloud vendor?

Managed Service

Which cloud workload monitoring tool was mentioned as an alternative to Auditd?

Falco

Task 7 - Conclusion

This room serves as a broad reference guide for essential AWS services like CloudTrail, CloudFront, and CloudWatch, designed for you to revisit as you dive deeper in future modules.

Mastering core cloud security concepts allows you to easily transition across platforms, as services like AWS CloudTrail, Azure Activity Log, and GCP Cloud Audit Logs share the same underlying security fundamentals.